COMPTIA SECURITY+ SY0-701 | DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

Security+ 2.1 · Threat Actors

Mestre CyberSec · **Aula 2.1 — Threat Actors** (10:23) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Quem ataca e POR QUÊ: nation-state (governo — espionagem/sabotagem, recursos enorme — APT); organized crime (lucro — ransomware, credential theft); hacktivist (ideologia — Anonymous); insider (dentro da casa — intencional ou descuidado); script kiddie (usa exploit pronto, volume)

💡 Highlights que a prova CompTIA cobra

- APT (Advanced Persistent Threat): government-backed — recursos enormes, target longo-prazo
- Organized crime = dinheiro; hacktivist = ideologia; nation-state = política/militar
- Script kiddie: usa exploit pronto — volume, pouca sofisticação
- Insider: o maior risco por já estar DENTRO da confiança

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'motivated by political/social ideology' = hacktivist
- 'long-term, nation-state, persistent' = APT

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.1 — Threat Actors)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Ator de Ameaça (N/A)

Qualquer pessoa ou grupo que intencionalmente ou acidentalmente cause dano a um sistema ou organização; categorizado por motivação, recursos e nível de sofisticação.

⚠ ***Armadilha CompTIA:*** *Gatilho: a prova SEMPRE dá a MOTIVAÇÃO e espera que você identifique o ator. Decore o mapeamento: dinheiro = organized crime, ideologia = hacktivist, política/militar = nation-state, dentro da empresa = insider, exploit pronto/volume = script kiddie.*

• Ameaça Persistente Avançada (APT)

Atacante altamente sofisticado e bem financiado — normalmente um nation-state — que mantém acesso furtivo de longo prazo à rede alvo para roubar dados ou realizar espionagem/sabotagem.

⚠ ***Armadilha CompTIA:*** *Gatilhos: 'long-term', 'persistent', 'nation-state', 'remains undetected for months/years', 'espionage'. Se a questão fala em ataque prolongado e oculto com muitos recursos, a resposta é APT — não organized crime nem script kiddie.*

• Ator de Estado-Nação (Governo) (N/A)

Atacante patrocinado por governo, com recursos enormes, ferramentas avançadas e capacidade de explorar zero-days, motivado por objetivos políticos, militares ou de espionagem.

⚠ ***Armadilha CompTIA:*** *Gatilho: 'government-sponsored', 'political/military motivation', 'espionage', 'zero-day', 'highest sophistication'. Distinção-chave: nation-state = política/espionagem com recursos ilimitados; organized crime = lucro; hacktivist = ideologia.*

• Crime Organizado (N/A)

Grupo criminoso estruturado motivado principalmente por ganho financeiro que usa ransomware, roubo de credenciais e fraude para monetizar ataques, frequentemente operando como serviço (Ransomware-as-a-Service).

⚠ ***Armadilha CompTIA:*** *Gatilho: 'financial gain', 'profit', 'ransomware', 'stolen credentials for sale', 'criminal syndicate'. Se a motivação é DINHEIRO, marque organized crime — nunca hacktivist (ideologia) nem nation-state (política).*

• Hacktivista (N/A)

Atacante movido por ideologia política ou social que usa técnicas de hacking (defacement, DDoS, vazamento de dados) para promover uma causa ou protestar contra uma organização; Anonymous é o exemplo clássico.

⚠️ ***Armadilha CompTIA:*** *Gatilho literal da prova: 'motivated by political or social ideology' = hacktivist. Se aparecer 'ideology', 'protest', 'cause' ou 'Anonymous', é hacktivist — não confunda com nation-state (política, mas patrocinado por governo).*

• Ameaça Interna (N/A)

Ameaça originada de alguém dentro da organização com acesso legítimo — funcionários, terceiros ou parceiros — agindo de forma maliciosa (roubo/sabotagem intencional) ou não intencional (negligência, shadow IT, cair em phishing).

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'already has access', 'trusted employee', 'inside the organization'. É o MAIOR risco porque já está dentro do perímetro de confiança e pode contornar controles externos. Lembre: insider pode ser INTENCIONAL ou ACCIDENTAL.*

• Script Kiddie (Atacante Não Qualificado) (N/A)

Atacante de baixa habilidade que usa exploits, ferramentas e scripts prontos feitos por outros para lançar ataques, gerando alto volume, mas baixa sofisticação e nenhuma capacidade própria.

⚠️ ***Armadilha CompTIA:*** *Gatilhos: 'uses pre-made tools/exploits', 'no technical skill', 'high volume', 'downloaded attack kit'. Distinção-chave: script kiddie = volume e pouca sofisticação; APT = stealth de longo prazo e muita sofisticação.*

• Shadow IT (TI Sombra) (N/A)

Hardware, software ou serviços em nuvem não autorizados usados por funcionários sem aprovação da TI, criando superfície de ataque não gerenciada e representando uma ameaça interna não intencional comum.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'employee installs/uses unapproved app or cloud service', 'no IT approval', 'bypasses security controls'. Se a questão aponta negligência interna SEM má intenção, pense em insider não intencional / shadow IT.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

O SOC de uma contratante de defesa descobre que um adversário manteve acesso persistente às redes de engenharia por 18 meses. Os investigadores encontram exploits zero-day, RATs customizados com múltiplos canais C2 redundantes e horários de operação alinhados ao fuso horário do país-alvo. Os dados roubados envolvem esquemas proprietários de propulsão. Qual ator de ameaça MELHOR corresponde a esse perfil?

A) Sindicato do crime organizado focado em fraude financeira

B) Ameaça persistente avançada (APT) de Estado-nação

C) Coletivo hacktivista em busca de publicidade

D) Script kiddie inexperiente usando exploits públicos

QUESTÃO 2 · CENÁRIO DE EXAME

Uma rede hospitalar regional é paralisada quando ransomware criptografa os sistemas de prontuários eletrônicos e exfiltra registros de pacientes. Os atacantes usaram ransomware commodity variante do LockBit entregue via kit de phishing, exigiram $4M em Monero e publicaram um cronômetro no site de vazamento ameaçando publicar os registros se não pagos. Qual perfil de ator de ameaça MELHOR se encaixa?

A) APT de Estado-nação realizando espionagem

B) Grupo hacktivista protestando contra política de saúde

C) Sindicato do crime organizado cibernético em busca de lucro

D) Ex-funcionário insatisfeito do TI do hospital

QUESTÃO 3 · CENÁRIO DE EXAME

Horas após uma decisão judicial controversa sobre privacidade de dados, o site público de uma empresa é desfigurado com slogans ideológicos e um banco de dados de clientes de 5GB é postado em um pastebin acompanhado por um manifesto político. Os atacantes usaram uma SQLi bem documentada em um formulário de login não corrigido e não fizeram pedido de resgate. Qual ator de ameaça é MAIS provavelmente responsável?

A) Grupo de crime organizado caçando cartões de crédito

B) APT de Estado-nação roubando inteligência estratégica

C) Script kiddie buscando diversão e notoriedade

D) Grupo hacktivista perseguindo objetivos ideológicos

QUESTÃO 4 · CENÁRIO DE EXAME

Um administrador sênior de banco de dados se demite em circunstâncias contenciosas. Duas semanas depois, a tabela inteira de clientes da empresa aparece à venda no marketplace de um concorrente. A revisão forense mostra que as credenciais privilegiadas do DBA foram usadas de uma geolocalização desconhecida durante horários fora do expediente na noite anterior à entrevista de saída. Qual categoria de ator de ameaça esse cenário MELHOR ilustra?

A) Ameaça persistente avançada externa

B) Coletivo hacktivista

C) Insider malicioso

D) Crime organizado recrutando externamente

QUESTÃO 5 · CENÁRIO DE EXAME

Um analista financeiro de uma empresa de investimentos recebe um e-mail que parece vir do CFO solicitando uma transferência urgente para um novo fornecedor internacional para uma aquisição confidencial. O e-mail usa spoofing de nome de exibição e um domínio semelhante. O analista transfere $850.000 sem realizar verificação fora de banda. Qual categoria de ator de ameaça MELHOR descreve o elemento humano que habilitou essa perda?

A) Insider não intencional / descuidado

B) Hacktivista

C) APT de Estado-nação

D) Operador de crime organizado

QUESTÃO 6 · CENÁRIO DE EXAME

Os logs do IDS de um provedor de hospedagem web mostram dezenas de milhares de tentativas de conexão de IPs diversos em múltiplos países, todas tentando explorar a CVE-2017-5638 (Apache Struts) — uma vulnerabilidade antiga, de quatro anos, bem divulgada. Os payloads são cópias idênticas de um módulo público do Metasploit, e os IPs de origem são em grande parte dispositivos IoT comprometidos e proxies abertos. Qual ator de ameaça MELHOR descreve essa atividade?

A) APT de Estado-nação conduzindo espionagem direcionada

B) Grupo hacktivista fazendo uma declaração política

C) Script kiddie / atacante inexperiente executando ferramentas automatizadas

D) Grupo de crime organizado implantando malware customizado

QUESTÃO 7 · CENÁRIO DE EXAME

Inteligência de ameaças indica que um adversário vem monitorando silenciosamente os sistemas SCADA de um conglomerado de mineração por 14 meses. Os objetivos do ator parecem ser inteligência estratégica sobre capacidades de extração de minerais de terras raras — não há tentativa de fraude financeira, nenhuma reivindicação pública e nenhuma atividade de resgate. A intrusão serve a competição estratégica de longo prazo entre nações. Qual categoria de ator de ameaça MELHOR corresponde a essas motivações e recursos?

A) Coletivo hacktivista

B) Sindicato de crime organizado

C) Insider insatisfeito

D) Ator de Estado-nação

QUESTÃO 8 · CENÁRIO DE EXAME

Uma equipe de resposta a incidentes está perfilando um ator de ameaça e observa os seguintes indicadores de capacidade: (1) posse de três vulnerabilidades zero-day previamente não divulgadas em software VPN corporativo, (2) implantes customizados com capacidades anti-forenses e de rootkit, (3) infraestrutura de comando e controle abrangendo roteadores comprometidos em três continentes usando técnicas de double-hop, e (4) tradecraft que consistentemente evita detecção por 12+ meses. Qual classificação MELHOR se aplica?

A) Script kiddie

B) Ameaça interna

C) Coletivo hacktivista

D) Ameaça persistente avançada (APT) de Estado-nação

QUESTÃO 9 · CENÁRIO DE EXAME

Durante uma revisão rotineira de governança de nuvem, o CISO descobre que o departamento de marketing vem usando uma plataforma SaaS não autorizada de pesquisa de clientes por dois anos para capturar e armazenar endereços de e-mail de clientes e dados parciais de pagamento — completamente fora dos processos de revisão de TI e segurança. Nenhuma violação ocorreu ainda. Qual classificação de risco MELHOR se aplica a essa exposição?

A) Vetor de espionagem de Estado-nação

B) Oportunidade de recrutamento hacktivista

C) Alvo de crime organizado

D) Shadow IT

QUESTÃO 10 · CENÁRIO DE EXAME

Uma investigação de longa duração revela um adversário que permaneceu em uma rede de serviços financeiros por mais de 14 meses, usando utilitários legítimos do Windows (PowerShell, WMI, PsExec) para movimento lateral, exfiltrando pequenas quantidades de dados semanalmente para evitar disparar limites de DLP, e pacientemente fazendo pivô através de redes de contratados para alcançar o alvo real. Qual termo MELHOR descreve esse comportamento do adversário?

A) Ataque de força bruta de credenciais

B) Campanha de negação de serviço distribuída

C) Ameaça persistente avançada (APT)

D) Evento isolado de exploração zero-day

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Ameaça persistente avançada (APT) de Estado-nação

As características de uma APT de Estado-nação estão presentes: (1) tempo de permanência longo medido em meses/anos, (2) vulnerabilidades zero-day que exigem investimento significativo em P&D, (3) malware customizado com infraestrutura C2 resiliente, (4) disciplina operacional alinhada ao fuso horário da vítima para se misturar ao tráfego normal, e (5) targeting de propriedade intelectual estratégica (projetos de propulsão) para vantagem geopolítica. O crime organizado busca monetização rápida; hacktivistas buscam visibilidade; script kiddies não conseguem produzir zero-days ou RATs customizados.

Questão 2: Alternativa C — Sindicato do crime organizado cibernético em busca de lucro

Grupos de crime organizado cibernético são caracterizados por: motivação financeira, uso de Ransomware-as-a-Service (RaaS) commodity como LockBit, demandas em criptomoedas, táticas de dupla extorsão (criptografar + ameaçar vazar) e phishing como vetor inicial. Saúde é alvo principal devido à urgência de serviço crítico que pressiona o pagamento rápido. Estados-nação não costumam extorcar hospitais; hacktivistas querem publicidade não dinheiro; insiders geralmente não têm a infraestrutura RaaS e a mecânica de cronômetro em site de vazamento.

Questão 3: Alternativa D — Grupo hacktivista perseguindo objetivos ideológicos

Hacktivistas são motivados por ideologia em vez de ganho financeiro. Indicadores-chave aqui: (1) timing diretamente ligado a um evento político/legal, (2) desfiguração e dump público de dados com manifesto em vez de monetização, (3) ausência de pedido de resgate, e (4) targeting destinado a envergonhar publicamente a organização. Crime organizado monetizaria os dados; um Estado-nação não se anunciaria via desfiguração; um script kiddie tipicamente carece do enquadramento ideológico e motivação política.

Questão 4: Alternativa C — Insider malicioso

Este é um cenário clássico de insider malicioso. Indicadores: (1) funcionário confiável com acesso privilegiado, (2) timing correlacionado com uma saída contenciosa, (3) abuso de credenciais legítimas (sem necessidade de exploits), (4) benefício financeiro direto para um concorrente, e (5) exfiltração de dados ocorrendo em horário fora do expediente quando o monitoramento é reduzido. APTs externos não teriam credenciais internas válidas ligadas a um funcionário em saída; hacktivistas não vendem dados a concorrentes; crime organizado tipicamente não teria posicionamento direto na organização.

Questão 5: Alternativa A — Insider não intencional / descuidado

O analista financeiro é a vítima de um ataque de Business Email Compromise (BEC) — mas do ponto de vista de modelagem de atores de ameaça, o humano que FALHOU com a organização é o insider não intencional/descuidado. Ele tinha o treinamento, as ferramentas e a política para verificar a solicitação, mas não exerceu o devido cuidado. A CompTIA categoriza explicitamente insiders como maliciosos (intencionais) ou não intencionais (descuidados/negligentes). Isso se enquadra diretamente na categoria de insider não intencional porque não há intenção maliciosa — apenas falha em seguir procedimentos de verificação.

Questão 6: Alternativa C — Script kiddie / atacante inexperiente executando ferramentas automatizadas

Script kiddies aproveitam ferramentas de exploração pré-construídas e publicamente disponíveis (ex.: Metasploit, Shodan) sem entender a vulnerabilidade subjacente. Indicadores aqui: (1) exploração de uma CVE antiga e bem conhecida em vez de pesquisa recente, (2) uso de módulo Metasploit verbatim — sem customização, (3) infraestrutura consistindo de dispositivos IoT comprometidos e proxies abertos (saída típica de botnet/scanner), (4) varredura oportunista de alto volume em vez de reconhecimento direcionado, e (5) ausência de evidência de sofisticação pós-exploração. Estados-nação, hacktivistas em operações ideológicas e crime organizado demonstram significativamente mais sofisticação e tooling customizado.

Questão 7: Alternativa D — Ator de Estado-nação

Atores de Estado-nação conduzem operações de inteligência de longo prazo alinhadas com interesses estratégicos nacionais. Indicadores-chave: (1) targeting de um setor ligado à segurança nacional de recursos (terras raras), (2) tempo de permanência longo medido em meses/anos, (3) foco em espionagem em vez de monetização, (4) ausência de atribuição pública (hacktivistas querem crédito), (5) ausência de motivo financeiro que o crime organizado perseguiria, e (6) targeting de SCADA típico de espionagem patrocinada por Estado. O enquadramento geopolítico de 'competição por recursos' é a pista definidora.

Questão 8: Alternativa D — Ameaça persistente avançada (APT) de Estado-nação

Esses indicadores de capacidade definem uma APT de Estado-nação. Vulnerabilidades zero-day requerem ou investimento massivo em P&D ou aquisição de brokers de vulnerabilidades, ambos exigindo financiamento de nível estatal. Implantes customizados com recursos anti-forenses exigem equipes de desenvolvedores qualificadas. C2 multi-

continental com encadeamento double-hop requer infraestrutura operacional significativa. Combinado com tempo de permanência longo, este é o perfil de capacidade clássico de uma APT. Script kiddies não conseguem produzir zero-days ou implantes customizados; insiders tipicamente carecem de infraestrutura C2 global; hacktivistas raramente possuem ou necessitam deste nível de tradecraft operacional.

Questão 9: Alternativa D — Shadow IT

Shadow IT refere-se a sistemas, soluções e dispositivos de TI implantados e usados dentro de uma organização sem aprovação organizacional explícita ou visibilidade do departamento de TI/segurança. O uso SaaS não autorizado da equipe de marketing se encaixa nessa definição com precisão. Shadow IT cria risco porque os sistemas ignoram controles de segurança, avaliações de fornecedores, classificação de dados, políticas de criptografia e planejamento de resposta a incidentes. A CompTIA inclui Shadow IT no domínio de atores de ameaça porque os sistemas não autorizados se tornam alvos fáceis para qualquer ator externo (crime organizado, APT, hacktivista) e frequentemente servem como pontos de exfiltração de dados ou pivô.

Questão 10: Alternativa C — Ameaça persistente avançada (APT)

Ameaça Persistente Avançada (APT) é definida por três atributos: (A)vançada — usa técnicas sofisticadas incluindo living-off-the-land binaries (LOLBins) para evadir detecção, (P)ersistente — mantém acesso de longo prazo (meses/anos) em vez de exploração rápida, e (T)hreat/Ameaça — possui recursos organizados e objetivo definido. Indicadores aqui: tempo de permanência de múltiplos meses, tradecraft LOLBin para se misturar com atividade administrativa, exfiltração baixa e lenta para evitar DLP, e pivô paciente através de supply-chain via contratados. Força bruta, DDoS e um evento zero-day único são todos ataques pontuais — não campanhas persistentes.